

- **Request:** A documented request should outline the reasons for change (e.g., business justification) and include details of the change (e.g., system to be changed, impact analysis to identify risks and affected systems, change time frame, and back-out plan).
- **Review:** Management should review requests to determine viability and business practicality.²⁵ Requests may be prioritized during this stage or may be returned to the request originator for more information.
- **Approve:** There should be a documented hierarchy for approving change requests. Appropriate approval mechanisms²⁶ should be commensurate with the scope, cost, urgency, and overall risk to the entity and its IT environment.
- **Design and build:** Management should follow formal processes to preserve integrity throughout the development life cycle and ensure adequate controls (e.g., restrictions for moving code from staging to production).
- **Test:** Management should document that the change performs as intended, identify any flaws (e.g., integrity issues), and verify that the change integrates with other systems.
- **Implement:** Management should follow a formal process to deploy the change during off-peak hours or planned system outages.
- **Verify and close:** After deployment, management should perform a post-implementation review to verify that the change was implemented successfully and achieved performance objectives. After verification, management should follow processes to document the change's closure.

Changes can pose risks to the confidentiality, integrity, and availability of the entity's IT environment. Therefore, management should preserve systems' security throughout the change management process. Improperly tested changes or changes implemented without approvals or documentation may cause systems to crash, return unanticipated results, allow the insertion of malicious code, or make it difficult for management to troubleshoot future problems. To minimize these risks, management should have processes to implement changes based on the change type. Entities often have the following types of changes:²⁷

- **Planned changes:** These changes follow the entity's complete process, often using most of the steps outlined in the preceding bullets, thereby addressing risks (e.g., potential for errors, unintended impacts to interrelated systems, or business process issues related to the unavailability of critical systems).
- **Routine changes:** These changes (e.g., installation of patches) are generally performed frequently or regularly and follow standard procedures. They may be pre-approved.
- **Emergency changes:** For this type of change (e.g., to restore a failed hardware component, respond to an ongoing cyber event, or address a service interruption), certain components of the change management process may be truncated or omitted out of necessity. Changes that

²⁵The review may be performed by IT management, stakeholders (e.g., service owner, technical staff, or financial personnel), or a formal committee (e.g., IT steering or operations) depending on the proposed change's scope, costs, risks, impact, and implementation time frame.

²⁶ Refer to the [NIST Glossary](#). Approval mechanisms may include a change advisory (or control) board, IT steering committee, management committee, or other personnel, depending on the entity's size and complexity.

²⁷ Entities often use different words to refer to these types of changes (sometimes even using the same words to refer to different types of changes). During examinations, examiners should use the entity's terminology.

are implemented because of an urgent need may carry substantial risk, given the lack of advance planning and testing. Therefore, all emergency changes should be reviewed and approved after implementation.

For more information, refer to the *IT Handbook*'s "[Development and Acquisition](#)" booklet.

III.D.2 Transitioning From Strategic Change Management to Day-to-Day Operations

Management should implement a process to transition system changes from a strategic change management process to day-to-day operations. The transition of responsibilities and knowledge should be part of the overall system development life cycle process as discussed in the *IT Handbook*'s "[Development and Acquisition](#)" booklet. Knowledge about IT processes gained through the change management process should be effectively transferred in a useful format to personnel responsible for operating the systems and processes. The efficient aggregation and organization of information allows management to reduce repeat service request inquiries, increase instances of self-driven problem solving, and encourage the level of overall knowledge within the entity.

III.E Oversight of Third-Party Service Providers

Many entities outsource the AIO activities to one or more third-party service providers, often depending on the entity's size and complexity and the level of expertise available in-house. Management should identify the internal and external roles and responsibilities for AIO activities and implement processes to oversee the activities performed by third-party service providers on the entity's behalf. The responsibility and oversight, if properly assigned and defined, should interact as seamlessly as possible to ensure that management identifies and addresses all risks according to contracts and other agreements (e.g., SLAs). Management should be aware of the data destruction processes maintained by the entity's third-party services providers, including cloud service providers.²⁸ The SLA should outline that the third-party service providers take adequate measures to ensure data destruction occurs in a manner that would prevent unauthorized disclosure of information.

Management should review independent audit or other assurance reports demonstrating the third-party service provider's ability to meet the entity's AIO needs and provide services in a safe and sound manner. Management should report to the board on the effectiveness of any AIO activities performed by third-party service providers and any issues uncovered through the entity's third-party risk management processes.

²⁸ See the [FFIEC Joint Statement: "Security in a Cloud Computing Environment."](#)

III.F Resilience

A secure and resilient IT environment,²⁹ including AIO functions, is essential to the delivery of an entity's critical services. An entity's AIO functions should be integrated into the entity's business continuity management (BCM) program to help management mitigate threats, respond to and recover from disruptions, and incorporate lessons learned to strengthen the entity's resilience.

Resilience of an entity's AIO functions extends beyond recovery capabilities. Resilience is achieved by taking proactive measures to maintain confidentiality, integrity, and availability and mitigating the risk of a disruptive event through system design (including backup systems), infrastructure selection, and IT deployment. The threats related to disruptive events may pose risks from multiple attack types (e.g., cyber and physical), duration (e.g., advanced persistent threat³⁰ [APT]), and delivery via deception (e.g., simultaneous distributed denial of service [DDOS] and business email compromise attacks). Management should design, implement, and operate its IT systems and processes to provide resilience for critical business activities. As part of its consideration for resilience of AIO functions, management should determine its reliance on people, processes, and technology, including third-party service providers, to assist in its assessment of risk.

Management should design systems and software with resilience (e.g., redundancy, additional layers of defense, and resilient backup systems) and information and cybersecurity (e.g., inspect and detect vulnerabilities and attacks) at the beginning of the architecture process. Management may include activities related to ITAM (e.g., inventory, audit, and testing) to demonstrate resilience effectiveness. Management may have differing design risks and oversight responsibilities in a cloud environment (i.e., because a cloud service provider often has different types of clients co-located, an entity may be affected by attacks aimed at other industry segments).

The entity's infrastructure should support varying levels of resilience depending on the criticality of the systems and software to ongoing business operations. For instance, management may use redundant servers, have alternate data centers, or employ backup as a service to provide the appropriate level of resilience. For both architecture design and infrastructure implementation, it is important to follow the entity's project management processes to appropriately integrate resilience throughout the enterprise. Following formal processes to integrate resilience may help inform strategic decision-making and effectively address resilience needs for the entity's core business lines. To maintain resilience, infrastructure should be implemented in a way that allows for secure remote administration and maintenance, for situations when personnel are unable to perform operations on-site.

²⁹ For larger or more complex entities, refer to the interagency paper *Sound Practices to Strengthen Operational Resilience* released by [FDIC](#), [FRB](#), and [OCC](#).

³⁰ Refer to [NIST SP 800-160 Volume 2, Developing Cyber Resilient Systems: A Systems Security Engineering Approach](#).

Management should address resilience in operations to prevent data loss, protect sensitive customer information from unauthorized disclosure or manipulation, minimize disruption to service delivery, and prevent the loss of situational awareness of the entity's operations. This involves having adaptable and comprehensive operational controls, operational processes (e.g., vulnerability and patch management), service delivery and support processes (e.g., resilience in supply chain), and ongoing monitoring and evaluation capabilities (e.g., monitoring for indicators of an APT).

When operating in, or planning a migration to, a cloud environment, management should not assume that systems are resilient. During migration to cloud services, management should identify the assets, applications, and services located in the cloud. Management should verify that resilience is covered in contracts with cloud service providers. Additional risk mitigation options may be available in a cloud environment, such as tools to enable backups or the ability to store backups in multiple locations. For more information, refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet.

III.G Remote Access

NIST defines remote access as access by users (or information systems) communicating external to an information system security perimeter. Examples of remote access include remote administration, access to the entity's network by third-party service providers, teleworker access, and customer access. Management should consider the implications of remote access in AIO.

When designing the entity's IT architecture for remote access capabilities, management should plan for the methods and access points that will be used across the enterprise to maintain security and control access to entity resources. Architectural design considerations include tunneling, web portals, direct application access, and remote desktop access.

- Tunneling involves establishing a secure communications tunnel, via encryption, between a telework client device and remote access servers within an entity, typically a virtual private network (VPN) gateway. When determining whether to use tunneling³¹ as a remote access method, management should consider the communications tunnel via encryption and the endpoints to which it is connected, as well as its capability to authenticate users and restrict access to IT systems.
- A portal³² is a server that offers access to one or more applications through a single centralized interface. A remote user accesses a portal client (e.g., a web browser) on a client device to access the portal. When determining whether to use a portal, management should consider whether it adequately protects communications between the client devices and the portal, and also whether it can authenticate users and restrict access to the entity's internal

³¹ Refer to NIST ITL Bulletin, [Security for Enterprise Telework, Remote Access, and Bring Your Own Device \(BYOD\) Solutions](#).

³² Examples of portals include web-based portal, terminal access server, or virtual desktop infrastructure. Refer to NIST ITL Bulletin, [Security for Enterprise Telework, Remote Access, and Bring Your Own Device \(BYOD\) Solutions](#).

resources. There is an important difference between tunnels and portals—the location of the application client software and associated data (i.e., in a tunnel, the software and data are on the client device; in a portal, they are on the portal server).³³

- Direct application access (e.g., webmail) occurs by accessing an individual application directly from most types of client devices without using remote access software. When determining whether to use this form of remote access, management should consider the security provided by the application, such as communications encryption and user authentication.
- Remote desktop access provides the ability to remotely control a particular desktop computer at the entity—most often, the user’s own computer at the organization’s office—from a telework client device. When determining whether to implement remote desktop access, management should consider limiting this method for exceptional use cases and implementing appropriate security controls (e.g., IAM and activity monitoring).

There are a number of risks associated with remote access, including unauthorized access, unrestricted privileged access, modification of information, inadequate monitoring, unencrypted communications, unpatched remote devices, and uncontrolled personally owned devices. Management should protect remote access technologies because they generally have a higher exposure to external threats compared with technologies accessed from inside the organization.³⁴ As more people work remotely, the scale of risk from remote access may increase. To mitigate risks associated with remote access, management should do the following:

- Develop and enforce a remote access policy that includes tiered levels of remote access and risk-based security controls over different types of remote access (e.g., remote administration and telework).
- Implement IAM based on job type and access and use appropriate authentication techniques (e.g., multi-factor authentication) for privileged access and activities, such as remote administration tasks.
- Use validated encryption technologies to protect communications between the entity and the remote user and encryption of sensitive data stored on the devices used for remote access.
- Securely configure remote access servers, including application of timely patch updates.
- Secure entity-owned telework client devices—including desktop and laptop computers, smartphones, and tablets—against common threats.
- Implement mitigating controls on the use of personally owned devices used to remotely access entity resources.

For more information on mitigating risks associated with entity-owned and personally owned devices, refer to the *IT Handbook*’s “[Information Security](#)” booklet.

³³ [Ibid.](#)

³⁴ [Ibid.](#)

III.H Personally Owned Devices

Personally owned and controlled user devices used for the entity's business purposes are known as bring your own device (also referred to as BYOD) resources. Personally owned devices may be used for remote access. They generally are not managed by the entity, creating the potential for an unsecured device to pose risks to the information that the user accesses and the entity's other connected systems and networks.³⁵ For example, a device compromised by a malicious user could be used to remotely access to the entity's network.

Before allowing the use of personally owned devices, management should perform due diligence on the types of devices that can be used. Management should consider the architecture of the entity's IT systems, to determine where and how personally owned devices will access the entity's network, in order to maintain appropriate security, segmentation, and access. Additional infrastructure (e.g., hardware and software) may be necessary to support the secure use of personally owned devices to access services. Management should determine the controls needed to adequately safeguard the network. Technical policy enforcement may ensure devices utilize anti-virus software and current operating systems, and that devices are not jailbroken.³⁶ For more information, refer to the *IT Handbook's* "[Information Security](#)" booklet.

III.I File Exchange

File exchange (also known as file sharing) is a method of sending and receiving files inside the entity and with other parties through email attachments, file sharing services, and other means. Risk considerations in file exchange include the following:³⁷

- Security deficiencies in file exchange methods (e.g., lack of encryption or use of weak encryption).
- File storage on untrusted servers controlled by third-party service providers leading to unauthorized access of the stored files and unapproved copies of the files.
- Files traversing untrusted networks, leading to unauthorized access (e.g., man-in-the-middle attacks or eavesdropping).
- Alteration (e.g., modification with incorrect information or injection of malicious code) of any file, even files without sensitive information.
- Solutions that are often difficult for users to set up and use (e.g., if the sender and recipient need to install software to exchange cryptographic keys).
- Use of unapproved, insecure, or ad hoc file exchange methods (e.g., shadow IT),
- Access to shared file repositories resulting in version control or unauthorized access issues.
- Identification of root causes of data exposure and measures to reduce the likelihood of its occurrence.

³⁵ [Ibid.](#)

³⁶ Refer to *FFIEC IT Handbook's* "Architecture, Infrastructure, and Operations" booklet [Glossary](#) for a definition of the term jailbreaking.

³⁷ NIST ITL Bulletin, "[Security Considerations for Exchanging Files Over the Internet.](#)"

Management should implement the following basic actions to improve the security of the entity's file exchange³⁸ activities:

- Identify user needs for exchanging files, both internally and externally. Identifying needs should include the senders and recipients, frequency of exchange, and nature of data being exchanged (e.g., public information, personally identifiable information, or proprietary).
- Design the client server architecture to provide for confidentiality, integrity, availability, and resilience. Examples of design considerations include the following:
 - File size and data complexity (e.g., XML or JSON (Java)).
 - Frequency of file updates.
 - File and data flows.
 - File usage by the various systems and by end users, including business unit usage.
 - Maintenance of security for files in transit and at rest.³⁹
- Identify the infrastructure, including the appropriate systems and software, necessary to support file exchange activities. File exchange solutions include email, file sharing services, managed file transfer, and custom applications (e.g., web and mobile). Often, entities may use more than one solution to meet their file exchange needs, in order to balance security and usability. Additionally, management should have appropriate infrastructure to support monitoring of the entity's file exchange activities. Some risk considerations in choosing a monitoring system include the following:
 - Monitoring for all methods of transferring files to third parties, including e-mail, copying information to external media, or use of shadow IT, which may not be visible to network security controls.
 - Capturing file exchanges between servers and between client devices and servers.
 - Monitoring beyond email to include monitoring of file exchanges happening through other means.
- Provide the appropriate operational controls, such as the following:
 - Conduct monitoring to ensure approved solutions are being used when needed to protect file exchanges, to avoid shadow IT solutions.
 - Include detection controls (e.g., IDS/IPS and firewalls) for inappropriate file sharing.
 - If using a third-party service provider file exchange solution, use only a trusted provider that employs appropriate controls for file exchange and storage solutions.
 - Consider solutions (e.g., cloud access security brokers (CASBs) for monitoring cloud-based file exchange and sharing capabilities) for providing visibility into cloud applications and their associated risks.
 - Define appropriate policies, standards, and procedures for file exchange activities.
 - Provide training to employees on approved solutions.

³⁸ [Ibid.](#)

³⁹ Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information.

IV ARCHITECTURE

Action Summary

Management should design, apply, and align its IT architecture to meet the strategic and business objectives of the enterprise. The architecture plan should meet the entity's needs for confidentiality, integrity, and availability to minimize operational and reputational risks resulting from poorly designed systems.

Examiners should review for the following:

- Identification of the entity's information and technology assets.
- Assessment of future enterprise IT needs.
- Documentation of the architecture plan, including policies, standards, and procedures.
- Development of appropriate design objectives, including changes, EOL, and identification of shadow IT.
- Design of IT architecture (e.g., in-house, virtualization and cloud, or hybrid).
- Documentation of EA elements.

Architecture refers to the manner in which the strategic design of the hardware and software infrastructure components (e.g., devices, systems, and networks) are organized and integrated to achieve and support the entity's business objectives. Planning and designing an effective IT architecture facilitate management's ability to implement infrastructure that aligns with the entity's strategic goals and business objectives.

Management should implement architecture principles that can be applied enterprise wide. When designing an entity's architecture, management should balance the mitigation of risks to various stakeholders, considering both the enterprise's needs as well as the needs of individual business units. Regardless of how management designs the entity's architecture, it should align the architecture with IT and business objectives, for example, providing maximum benefits with lowest risks and acceptable costs. The architecture's design should meet the entity's needs for confidentiality, integrity, and availability and adhere to the entity's policies, standards, and procedures. In addition, management should consider the entity's architecture requirements for its existing technology and any planned changes.

Management should clearly define its mission and any strategic initiatives for architecture. Business units should understand their portion of the design, which should align with management's mission and strategic initiatives. In determining its future architecture, management should first identify the entity's IT assets and external constraints, as well as industry IT architecture trends. Once management understands the entity's current state of architecture, management should perform a gap analysis to determine the requirements to reach its future state.

Management should have policies, standards, and procedures to govern the entity's architecture design process. The design process should address the following:

- Definition of responsibilities and decision-making.
- Identification of functional requirements.
- Assessment of alignment with the entity's IT and strategic plans.
- Evaluation of the inventory of current IT assets and the purpose of those assets.
- Performance of a cost-benefit analysis of the architecture plan or project.
- Acquisition of approvals for the initiative.
- Implementation and maintenance of the architecture.
- Resolution of disputes or architectural issues.

Poorly designed architecture can lead to issues with confidentiality, integrity, and availability in both infrastructure and operations.

IV.A Architecture Plan

Management should have a documented and approved architecture plan that identifies the entity's current state. The architecture plan should align with the entity's strategic plan to support the business and strategic objectives of the entity. Management should have policies, standards, and procedures that govern architecture initiatives and changes to the architecture plan. There should be processes including obtaining approvals for initiatives, making changes to the plan, and reporting to management or the board as appropriate.

Smaller or less complex entities may have a less structured architecture plan and generally have fewer initiatives or changes to the plan. Larger or more complex entities often have complex architecture plans, architecture review processes, and architecture boards or planning groups to ensure that initiatives are carried out according to architectural principles.

When the entity is planning larger or more complex architecture changes, implementation of those changes should maintain and follow a project management process that includes the following phases:

- Plan (e.g., identify requirements and functional specifications and design technical architecture).
- Execute (e.g., build and implement solution and monitor and control risks).
- Closeout (e.g., update documentation and incorporate lessons learned into the architecture plan).

IV.B Design Objectives

An architecture process creates a systematic approach to streamline the design process and provides management with a plan to organize and integrate new hardware and software with existing infrastructure. When designed properly, the process can help maintain agility and flexibility in meeting changing business needs. Hardware and software selection and

implementation rely on the collaboration between IT and business line management. A fundamental step is to define terminology to provide a common set of terms used by IT and business unit personnel to design the entity's architectural process. Management should evaluate its needs and consider the following:

- Collaboration between IT and business units.
- Prioritization of investments.
- Comparison of existing architecture with long-term goals and anticipated future needs and changes.
- Establishment of processes to evaluate and procure technology.
- Storage (e.g., network-attached storage and storage area network [SAN]), backup, and capacity needs to accommodate the entity's strategic plans.
- Whether the architecture will support internet-facing applications, internal network applications, or both.

Management should include the following aspects in its architecture design:

- Performance and reliability (e.g., system processing at normal and peak loads, response time, load balancing, and uptime required by end users).
- Integrity (e.g., validation checks to promote accuracy).
- Availability and resilience (e.g., meeting recovery time objective [RTO] and recovery point objective [RPO] requirements, providing redundancy, and avoiding single points of failure).
- Scalability (e.g., the ability of systems and software to accommodate growth).
- Flexibility (e.g., the ability of systems and software to accommodate changes without requiring new hardware or code changes).
- Security and privacy throughout the entity's network (e.g., IAM controls and data loss prevention).
- Interoperability⁴⁰ and integration (e.g., among OSs, databases, networks, and user interfaces, and loose coupling).
- Ability to integrate and align with one or more third-party service providers.⁴¹
- Testing (e.g., integration and business continuity testing) internally and with third-party service providers as appropriate.
- Auditability (e.g., audit trails and logs).
- Advancements in technology.

The design objectives should include considerations for avoiding the potential for shadow IT. Management should design its systems to provide the capability to monitor and alert for the use of shadow IT because shadow IT uses entity resources and could provide unknown avenues for exploitation. Management should consider how evolving technologies (e.g., cloud, IoT, and artificial intelligence [AI] and machine learning [ML]) can affect its systems' design.

⁴⁰ For supervisory purposes, interoperability refers to the ability of data, systems, or software to work with or on multiple systems or software.

⁴¹ Situations where the entity's IT architectural design does not align with the third-party service provider's systems, resulting in difficulty managing integration (e.g., costs of making manual changes, security issues, and errors and omissions) between the entity and its third-party service provider.